

VULNERABILITY ASSESSMENT REPORT: BSF-NUTRIFEED

Introduction

The purpose of this Vulnerability Assessment Report is to evaluate the security posture of the BSF-Nutrifeed simulated ecosystem. Due to the unavailability of direct access to the organization’s live infrastructure, this assessment was conducted within a controlled virtual lab environment. The lab environment represents key components of the ecosystem, specifically a vulnerable production server and an employee workstation, simulated using Metasploitable 2 and Windows 11 VM respectively.

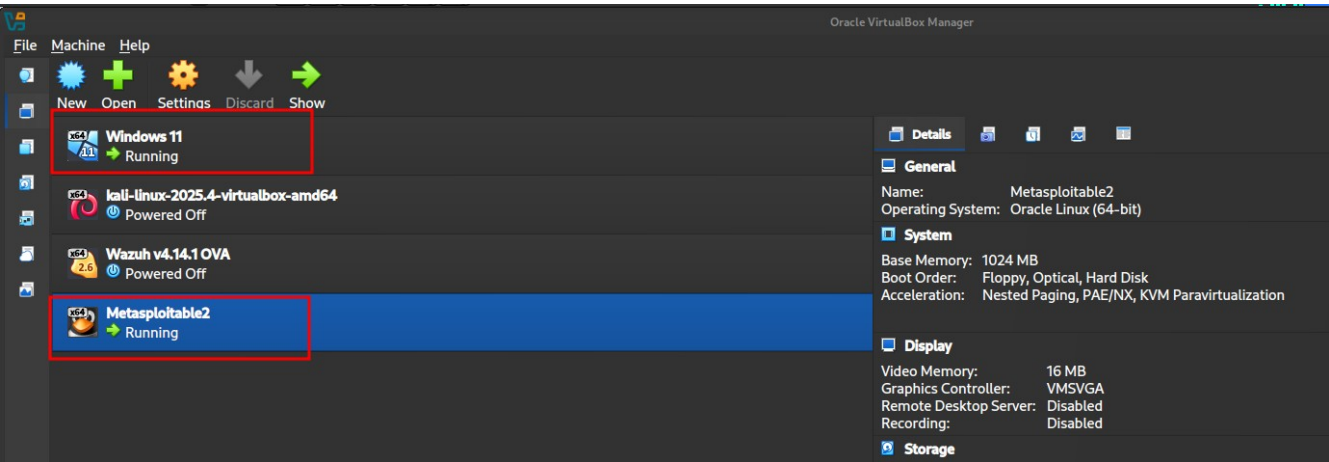
This report focuses on identifying active services running on the selected systems through network scanning techniques, analyzing potential vulnerabilities associated with these services, and assessing the level of risk they pose to the overall environment. Vulnerabilities are categorized into low, medium, and high risk levels based on their potential impact and ease of exploitation.

Furthermore, the report provides practical recommendations to mitigate the identified vulnerabilities and strengthen the security posture of the simulated BSF-Nutrifeed ecosystem. The overall objective is to highlight critical security gaps and propose actionable measures to enhance resilience against potential cyber threats.

1. BSF-Nutrifeed Ecosystem

S/n	Components	Lab VM/Tool
1	Production server	Metasploitable2
2	Employee PC	Windows 11 VM

2. Ensuring all target VMs are running



3. IP Address Discovery

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0  
        valid_lft 498sec preferred_lft 498sec  
    inet6 fe80::14c2:90e7:9fce:cd0/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~]  
$
```

4. Discovering Active Hosts/Devices

Run: `nmap -sn 192.168.56.0/24`

```
(kali@kali)-[~]  
$ nmap -sn 192.168.56.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 18:05 EDT  
Nmap scan report for 192.168.56.1  
Host is up (0.0013s latency).  
MAC Address: 0A:00:27:00:00:00 (Unknown)  
Nmap scan report for 192.168.56.100  
Host is up (0.0044s latency).  
MAC Address: 08:00:27:60:B4:7C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.101  
Host is up (0.0053s latency).  
MAC Address: 08:00:27:0D:DC:1B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.103  
Host is up (0.0044s latency).  
MAC Address: 08:00:27:E2:9A:68 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.102  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 27.86 seconds  
(kali@kali)-[~]  
$
```

5. Identifying Services & Versions

i) Metasploitable 2: Run `nmap -sV 192.168.56.101`

ii) Windows 11 VM: `nmap -sV 192.168.56.103`

i) Metasploitable 2 Scanning

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:0d:dc:1b
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe0d:dc1b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:3 errors:0 dropped:0 overruns:0 frame:0
          TX packets:29 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:1252 (1.2 KB)  TX bytes:3638 (3.5 KB)
          Base address:0xd020  Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:91 errors:0 dropped:0 overruns:0 frame:0
          TX packets:91 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19301 (18.8 KB)  TX bytes:19301 (18.8 KB)

msfadmin@metasploitable:~$
```

```
(kali㉿kali)-[~]
$ nmap -sV 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-26 04:09 EDT
Nmap scan report for 192.168.56.101
Host is up (0.00021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rrexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
```

ii) Windows 11 VM Scanning

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\WINDOWS\system32> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::674e:340d:42e:d407%9
    IPv4 Address. . . . . : 192.168.56.103
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 

PS C:\WINDOWS\system32> |
```

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap -sV 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-26 03:52 EDT
Nmap scan report for 192.168.56.103
Host is up (0.0026s latency).
All 1000 scanned ports on 192.168.56.103 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:00:27:E2:9A:68 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Service detection performed. Please report any incorrect results at https://n
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.24 seconds

(kali@kali)-[~]
$
```

Notice:

A full port scan of all 65,535 ports was not performed on the Windows 11 system due to time constraints and the presence of host-based firewall filtering, which significantly increases scan duration. Instead, a targeted scan of the most common ports was conducted, which is sufficient for identifying typical exposure points in a secured environment.

Metasploitable 2					Windows VM
192.168.56.101	Port	State	Service	Version	192.168.56.103

	21/tcp	open	ftp	vsftpd 2.3.4	The Windows 11 VM at 192.168.56.103 showed all scanned TCP ports as filtered due to firewall protection and absence of externally listening services. This indicates a minimal attack surface, which is a positive security control within the BSF-Nutrifeed simulated ecosystem
	22/tcp	open	ssh	OpenSSH 4.7p1	
	23/tcp	open	telnet	Linux telnetd	
	25/tcp	open	smtp	Postfix smtpd	
	53/tcp	open	domain	ISC BIND 9.4.2	
	80/tcp	open	http	Apache httpd 2.2.8	
	111/tcp	open	rpcbind	2 (RPC #100000)	
	139/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X	
	445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X	
	512/tcp	open	exec	netkit-rsh rexecd	
	513/tcp	open	login	OpenBSD	
	514/tcp	open	shell	Netkit rshd	
	1099/tcp	open	java-rmi	GNU Classpath grmiregistry	
	1524/tcp	open	bindshell	Metasploitable root shell	
	2049/tcp	open	nfs	2-4 (RPC #100003)	
	2121/tcp	open	ftp	ProFTPD 1.3.1	
	3306/tcp	open	mysql	MySQL 5.0.51a-3ubuntu5	
	5432/tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7	
	5900/tcp	open	vnc	VNC (protocol 3.3)	
	6000/tcp	open	x11	(access denied)	
	6667/tcp	open	irc	UnrealIRCd	
	8009/tcp	open	ajp13	Apache Jserv (Protocol v1.3)	
	8180/tcp	open	http	Apache Tomcat/Coyote JSP	

				engine 1.1	
--	--	--	--	------------	--

6. Running Vulnerability script

Host: 192.168.56.101

Run: nmap --script vuln -p

21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,5432,5900,6000,6667,8009,8180 192.168.56.101

7. Key identified services and vulnerabilities

a) Vulnerability Analysis Table

i) High Risk Vulnerabilities

Port	Service	Vulnerability	Risk	Recommendation
21	FTP (vsftpd 2.3.4)	Backdoor (CVE-2011-2523)	● High	Disable FTP or upgrade to secure version
23	Telnet	Cleartext authentication	● High	Disable Telnet, use SSH
1099	RMI Registry	RMI Registry	● High	Remote Code Execution
6667	IRC	UnrealIRCd backdoor	● High	Remove or patch IRC service
5432	PostgreSQL	SSL MITM (CVE-2014-0224)	● High	SSL MITM (CVE-2014-0224)
25	SMTP	Weak SSL/TLS (POODLE, Logjam)	● High	Disable SSLv3, enforce TLS 1.2+
80	HTTP	SQL Injection + CSRF + Slowloris	● High	Input validation, WAF, patch apps

ii) Medium Risk Vulnerabilities

Port	Service	Vulnerability	Risk	Recommendation
22	SSH	Potential brute-force risk	● Medium	Use strong passwords, disable root login
139/445	SMB	File sharing exposure	● Medium	Restrict access, disable SMBv1
3306	MySQL	Open database port	● Medium	Restrict remote access
2049	NFS	Unauthorized file access	● Medium	Apply access control
5900	VNC	Remote desktop exposure	● Medium	Use authentication + firewall

8009	AJP13	Apache Tomcat exposure	● Medium	Disable if unused
------	-------	------------------------	----------	-------------------

iii) Low Risk Vulnerabilities

Port	Service	Vulnerability	Risk	Recommendation
53	DNS	Open Service	● Low	Restrict to trusted networks
111	RPCBind	Service enumeration	● Low	Limit exposure
512–514	R-services	Legacy insecure services	● Low	Disable services
8180	HTTP Admin	Missing cookie flags	● Low	Enable HttpOnly & Secure flags

b) Critical Findings

Findings	Description	Impact	Risk	Recommendation
FTP Backdoor (vsftpd 2.3.4)	FTP Backdoor (vsftpd 2.3.4)	Backdoor allows remote root access (uid=0)	● High	Disable or upgrade FTP service
Weak Encryption (POODLE, Logjam, Weak DH)	Use of outdated SSL/TLS protocols	Data interception, MITM attacks	● High	Enforce TLS 1.2+, disable weak ciphers
Web Application Vulnerabilities	SQL Injection, CSRF, file upload flaws	Database compromise, account takeover	● High	Input validation, WAF, patch apps
Legacy/Insecure Services	Telnet, R-services, IRC backdoor	Unauthorized remote access	● High	Disable unused/insecure services

8. Vulnerability Assessment Report Summary

The Metasploitable 2 system exhibits multiple critical vulnerabilities across several exposed services. High-risk issues include a known FTP backdoor, insecure remote access protocols such as Telnet, and multiple cryptographic weaknesses affecting secure communications. Additionally, web application vulnerabilities such as SQL injection and cross-site request forgery significantly increase the risk of compromise.

The presence of outdated and insecure services indicates poor system hardening and lack of security controls, making the system highly susceptible to exploitation. Immediate remediation is required to reduce the attack surface and improve the overall security posture of the BSF-Nutrifeed simulated environment.

9. Recommendations

- i) Disable all unnecessary services (Telnet, IRC, R-services)
- ii) Patch outdated software (FTP, OpenSSL, Apache)
- iii) Enforce strong encryption (TLS 1.2+)
- iv) Implement firewall restrictions
- v) Secure web applications (input validation, WAF)
- vi) Restrict database and file-sharing access

10. Conclusion

Overall, the system demonstrates a high-risk security posture due to the combination of exploitable vulnerabilities, weak configurations, and unnecessary exposed services. Immediate corrective actions are required to mitigate the identified risks and improve system resilience.